

Cybersecurity Daily Newsletter

Vol. 003 | 2026-07-20 09:00 WIB

Top 5 Highlights

- ISC Stormcast For Monday, July 20th, 2026 <https://isc.sans.edu/podcastdetail/10014>, (Mon, Jul 20th)
- Critical NGINX Vulnerability Can Crash Workers and May Allow Remote Code Execution
- UAC-0145 Uses ClickFix CAPTCHAs to Infect Ukrainian Devices with Malware
- SonicWall SMA Zero-Days Exploited Before Disclosure to Gain Root Access
- [+24h Old] Week in review: High severity WordPress vulnerabilities, fake OAuth IDs bypass sign-in logs

Threat Intelligence (10)

01. ISC Stormcast For Monday, July 20th, 2026

<https://isc.sans.edu/podcastdetail/10014>, (Mon, Jul 20th)

ISC Stormcast For Monday, July 20th, 2026 <https://isc.sans.edu/podcastdetail/10014>, (Mon, Jul 20th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33166>

02. UAC-0145 Uses ClickFix CAPTCHAs to Infect Ukrainian Devices with Malware

Russian state-sponsored threat actors have been observed leveraging the infamous ClickFix strategy to trick Ukrainian targets into infecting their own machines with data-stealing malware. According to the Computer Emergency Response Team of Ukraine (CERT-UA), the activity has been attributed to UAC-0145, a sub-cluster within Sandworm, an advanced hacking un...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/uac-0145-uses-clickfix-captchas-to.html>

03. [+24h Old] Microsoft warns of surge in ACR Stealer attacks on customers

Microsoft has observed a surge in attacks using the ACR Stealer malware to steal browser-stored passwords, authentication tokens, and sensitive documents from its enterprise customers. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/microsoft-warns-of-surge-in-acr-stealer-attacks-on-customers/>

04. [+48h Old] New North Korean campaign uses fake coding interviews to steal developer credentials

DPRK-aligned hackers hid malware inside SVG flag images to backdoor developer job interview coding tests. Not one antivirus vendor caught it.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.elastic.co/security-labs/contagious-interview-malware-svg-steganography>

05. [+48h Old] New Russian-speaking threat actor UAT-11795 targets US and Europe with novel malware

UAT-11795 utilizes novel tools, including the Python-based Starland RAT and the PowerShell-based WLDR agent, which operates entirely in-memory with encrypted beaconing and a Runspace execution engine.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/new-russian-speaking-threat-actor-uat-11795-targets-us-and-europe-with-novel-malware>

06. [+48h Old] MacOS malware hijacks Telegram sessions, targets crypto wallets

The macOS malware targets information stored locally on infected devices, including passwords, browser cookies, Apple Notes and Telegram Desktop session files.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.scworld.com/brief/mac-os-malware-hijacks-telegram-sessions-targets-crypto-wallets>

07. [+48h Old] Over 1 million malicious emails found using text salting to fool AI scanners

Text salting fills emails with hidden benign content to mask malicious phishing lures.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.scworld.com/news/over-1-million-malicious-emails-found-using-text-salting-to-fool-ai-scanners>

08. [+48h Old] Seven Malicious Vite npm Packages Use Blockchain C2 to Deliver a RAT

Cybersecurity researchers have discovered a cluster of seven malicious npm packages targeting the Vite frontend tooling ecosystem as part of a software supply chain attack. The malicious package campaign, codenamed ViteVenom by Checkmarx, marks an expansion of ChainVeil, which was observed using an "unprecedented" four-tier blockchain-based command-and-control...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://thehackernews.com/2026/07/seven-malicious-vite-npm-packages-use.html>

09. [+48h Old] New NadMesh Botnet Hunts Exposed AI Services for Cloud Keys and Kubernetes Tokens

A Go botnet called NadMesh turned up in early July hunting exposed AI services, and the operator's own dashboard claims 3,811 unique AWS keys. A Shodan harvester keeps the scan queue stocked with ComfyUI, Ollama, n8n, Open WebUI, Langflow, and Gradio: the image generators, local model runners, and workflow builders that teams stand up fast and firewall late...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/07/new-nadmesh-botnet-hunts-exposed-ai.html>

10. [+48h Old] The Good, the Bad and the Ugly in Cybersecurity - Week 29

Authorities sanction Russian-based cybercriminals, attackers deploy Starland malware, and 300 imposter GitHub repos push BoryptGrab infostealer.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.sentinelone.com/blog/the-good-the-bad-and-the-ugly-in-cybersecurity-week-29-8/>

Latest Vulnerabilities (10)

01. Critical NGINX Vulnerability Can Crash Workers and May Allow Remote Code Execution

F5 has shipped fixes for a critical nginx flaw that lets a remote, unauthenticated attacker trigger a heap buffer overflow in the worker process with crafted HTTP requests. CVE-2026-42533 was patched on July 15 in nginx 1.30.4 (stable) and 1.31.3 (mainline), and in NGINX Plus 37.0.3.1; anyone on an earlier build should upgrade. Triggering it can crash or re...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/critical-nginx-vulnerability-can-crash.html>

02. SonicWall SMA Zero-Days Exploited Before Disclosure to Gain Root Access

A previously undocumented threat actor has been attributed to the exploitation of recently disclosed SonicWall Secure Mobile Access (SMA) 1000 series VPN appliances as zero-days prior their public disclosure since June 22, 2026. Cybersecurity company Volexity is tracking the activity under the moniker UTA0533. The discovery was made following an incident re...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/sonicwall-sma-zero-days-exploited.html>

03. [+24h Old] Week in review: High severity WordPress vulnerabilities, fake OAuth IDs bypass sign-in logs

Here's an overview of some of last week's most interesting news, articles, interviews and videos: Two new high severity WordPress vulnerabilities, patch immediately! The 7.0.2 WordPress security release addresses one critical and one high severity security issue. Cynative: Open-source deep research agent Running a large language model against a live cloud a...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.helpnetsecurity.com/2026/07/19/week-in-review-oauth-client-ids-spoofed-sonicwall-sma-appliances-targeted-in-zero-day-attacks/>

04. [+24h Old] Update now: 7-Zip fixes RCE flaw exploitable with malicious archives

7-Zip version 26.02 was released on June 25 to fix a remote code execution vulnerability that could allow attackers to execute malicious code by convincing users to open specially crafted compressed files. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/update-now-7-zip-fixes-rce-flaw-exploitable-with-malicious-archives/>

05. [+24h Old] WordPress Core "wp2shell" RCE flaws get public exploits, patch now

Public exploits have been released for the critical "wp2shell" remote code execution vulnerabilities affecting WordPress Core, making it imperative that administrators patch their sites immediately. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/wordpress-core-wp2shell-rce-flaws-get-public-exploits-patch-now/>

06. [+24h Old] Two new high severity WordPress vulnerabilities, patch immediately!

The 7.0.2 WordPress security release addresses one critical and one high severity security issue. The vulnerabilities reported to the WordPress security team include:
CVE-2026-60137 - A facilitated SQL injection issue reported as a team by TF1T, dtro, and haongo
CVE-2026-63030 - A REST API batch-route confusion and SQL injection issue leading to Remote Code...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.helpnetsecurity.com/2026/07/18/wordpress-vulnerabilities-wp2shell-cve-2026-60137-cve-2026-60137/>

07. [+48h Old] ACR Stealer exploits user interaction to steal sensitive data

Microsoft has detailed two primary intrusion chains used by ACR Stealer.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/acr-stealer-exploits-user-interaction-to-steal-sensitive-data>

08. [+48h Old] SoftBank leverages OpenAI for AI-driven cybersecurity patching service

SoftBank's "Patching as a Service" (PaaS), powered by a joint venture with OpenAI called SB OAI Japan, offers clients AI-infused remediation planning and vulnerability assessment.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/softbank-leverages-openai-for-ai-driven-cybersecurity-patching-service>

09. [+48h Old] New wp2shell WordPress Core Flaw Lets Unauthenticated Attackers Run Code

Updated July 18, 2026: the two flaws now carry CVE IDs, the full mechanism has been published, a persistent-object-cache condition has surfaced, and a working proof-of-concept is public. The story below reflects all of it. An anonymous HTTP request can run code on a WordPress site. The bug is in core, so a bare install with zero plugins is

exploitable. Ever...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/new-wp2shell-wordpress-core-flaw-lets.html>

10. [+48h Old] OpenSSL HollowByte Flaw Could Freeze Server Memory with 11-Byte TLS Requests

Eleven bytes will make an unpatched OpenSSL server set aside up to 131 KB of memory for a message that never arrives. On the glibc systems Okta tested, that memory is gone until the process restarts. OpenSSL shipped the HollowByte fix in June with no CVE, no advisory, and no changelog entry pointing at it. Okta's Red Team, which reported the denial-of-servi...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/07/openssl-hollowbyte-flaw-could-freeze.html>

Data Breach & Cybercrime (10)

01. [+48h Old] 2 charged in New York for laundering \$43 million from investment scams

Zhuoying Chen, 27, and Haojie Zhang, 38, are accused of managing a network that transferred at least \$43 million to China, based on information published by Bleeping Computer.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/two-charged-in-new-york-for-laundering-43-million-from-investment-scams>

02. [+48h Old] Lawyers say Russian tourist detained in Armenia over mistaken identity in ransomware case

The detained Russian, Aleksandr Yuryevich Ermakov, was apprehended in Armenia on June 28, based on a U.S. request.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.scworld.com/brief/russian-tourist-detained-in-armenia-over-mistaken-identity-in-us-extradition-request>

03. [+48h Old] Abbott probes two cyber incidents amid extortion claims

Abbott Laboratories is investigating two separate cybersecurity incidents after confirming unauthorized access to internal legacy Exact Sciences systems in its Cancer Diagnostics business, while also investigating a separate claim that attackers breached its LabCentral portal and stole company data. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/abbott-laboratories-probes-two-cyber-incidents-amid-extortion-claims/>

04. [+48h Old] OnlyFans performers become unlikely allies of CISOs in securing websites

CISOs at government organizations and universities have an unexpected ally coming to their aid: OnlyFans models. For some time, hackers have exploited weaknesses in the websites of universities or government departments to host scams or malware, using content stolen from the OnlyFans website as bait to attract victims. Now, according to security researchers...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.csoononline.com/article/4198478/onlyfans-performers-become-unlikely-allies-of-cisos-in-securing-websites.html>

05. [+48h Old] GoldenEyeDog Subgroup Linked to DigiCert Breach and Code-Signing Certificate Theft

Cybersecurity researchers have attributed the April 2026 DigiCert security incident to a threat activity cluster dubbed CylindricalCanine. Expel, which shared technical details of the event, described the threat actor as a sub-group of GoldenEyeDog (aka APT-Q-27, Dragon Breath, and Miutu Group), a Chinese cybercrime group known for its targeting of the gam...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/07/goldeneyedog-subgroup-linked-to.html>

06. [+48h Old] Government Agencies Falling Victim to Ransomware Daily, Warns Study

Government organizations are targeted by attackers who know agencies cannot afford disruption to public services

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/government-ransomware-daily/>

07. [+48h Old] Ernst & Young discloses data breach after support system hack

Ernst & Young is notifying customers of a data breach caused by the compromise of a third-party support ticket system used by its IT personnel. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/ernst-and-young-discloses-data-breach-after-support-system-hack/>

08. [+48h Old] 23andMe Faces New Security Mandates in \$18m Data Breach Settlement

23andMe has agreed to an \$18m settlement with 42 US attorneys general over its 2023 data breach, including enhanced data protection requirements

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.infosecurity-magazine.com/news/23andme-18m-data-breach-settlement/>

09. [+48h Old] In Other News: Iran Tracks US Military Phones, CrashStealer macOS Malware, CVD Blueprint

Noteworthy stories that might have slipped under the radar: OpenClaw AI agents exploited via WhatsApp, ransomware hits naval defense firm TKMS, Lidl discloses data breach. The post In Other News: Iran Tracks US Military Phones, CrashStealer macOS Malware, CVD Blueprint appeared first on SecurityWeek .

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.securityweek.com/in-other-news-iran-tracks-us-military-phones-crashstealer-macos-malware-cvd-blueprint/>

10. [+48h Old] Inside the Search for "Clean" Residential Proxies for Carding

Residential proxies are no longer the silver bullet they once were for carding. Flare explains why cybercriminals increasingly seek "clean" residential proxies and combine them with browser fingerprints, device profiles, and other identity signals to evade modern fraud detection. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/inside-the-search-for-clean-residential-proxies-for-carding/>